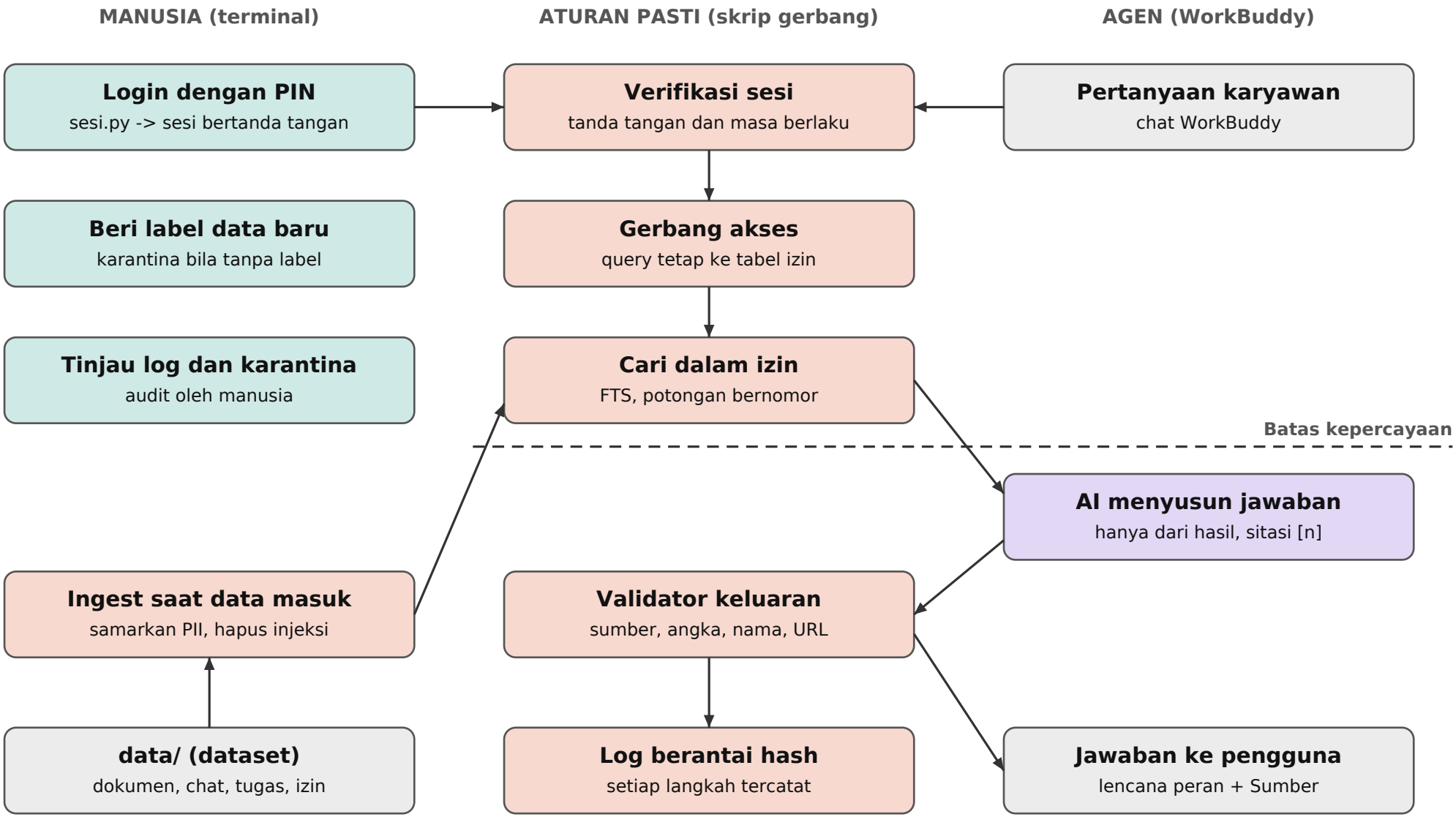
Pustaka Aman: arsitektur dan batas kepercayaan

Challenge A · The Workplace Brain



Prinsip desain dan trade-off

Prinsip	Penjelasan
AI diapit aturan pasti	Gerbang sebelum AI menentukan data apa yang boleh dilihat; validator sesudah AI memeriksa jawaban. Keduanya skrip, bukan instruksi, sehingga tidak bisa dibujuk.
Identitas dari sesi, bukan chat	Manusia login di terminal dengan PIN. Sesi ditandatangani kunci di luar workspace. Agen tidak punya parameter identitas; klaim identitas di chat diabaikan dan dicatat.
Penolakan simetris	Jawaban untuk hal yang tidak boleh diketahui identik dengan hal yang tidak ada, sehingga penolakan tidak membocorkan keberadaan data.
Data adalah data	Instruksi untuk AI di dokumen dihapus sebelum diindeks; file dengan teks tersembunyi dikarantina utuh.
Gagal tertutup	Tanpa label = karantina; file tak terbaca = ditolak; sesi tidak sah = ditolak; error tidak boleh menyamar sebagai 'tidak ditemukan'.

Trade-off	Pilihan kami	Alasan
Data di laptop vs di server	Demo: data di folder proyek. Produksi: gerbang menjadi API server (mis. HRIS) dengan SSO	Juri bisa menjalankan demo; versi produksi menghilangkan risiko AI membaca file langsung
Kata kunci vs semantik	Pencarian kata kunci SQLite FTS5	Cepat, deterministik, tanpa dependensi; kelemahannya terlihat di TC-12
Satu panggilan AI vs agen pemeriksa	Validator berbasis skrip	Lebih cepat dan tidak bisa tertipu; cocok untuk tes 90 detik

Accountability sheet

Bagian	Isi
Yang bisa diakses agen	Hanya keluaran skrip gerbang: potongan data yang lolos tabel izin untuk pengguna yang login, sudah disamarkan dan dibersihkan dari instruksi tersisip.
Dikerjakan otomatis	Mencari dalam izin, menyusun jawaban bersitasi, validasi keluaran, mencatat log, membangun ulang indeks saat data atau izin berubah.
Butuh manusia	Login dan ganti pengguna (terminal + PIN); memberi label data di karantina; meninjau kalimat injeksi yang dihapus; membuat PIN dan kunci.
Tidak akan pernah	Memilih atau mengganti identitas; menampilkan sumber di luar izin, angka yang tidak ada di sumber, nama data rahasia, atau data pribadi utuh; menjalankan instruksi dari dalam data; menyebut bahwa ada data yang disaring.
Catatan	Log berantai hash: login, pertanyaan, sumber yang diambil, keputusan validasi, klaim identitas, indikasi injeksi. Perintah 'tunjukkan log' dan 'periksa-log'.
Batasan yang diketahui	F-01: tanpa skill aktif, WorkBuddy membaca file sendiri dan membocorkan data (dimitigasi dengan Expert, AGENTS.md, desain produksi berbasis server). TC-12: pencarian kata kunci bukan makna. Dua pertahanan masih bersandar pada AI: tidak membuka folder data langsung, dan tidak menulis narasi proses. Login terminal adalah simulasi SSO.

Ringkasan hasil uji

Lapis	Hasil	Catatan
Percakapan di WorkBuddy (6 Nov 2026)	9/9 lulus keamanan	Tanpa kebocoran, identitas tidak berganti, Kenari = Zebra. 5 temuan kualitas (mis. satu jawaban 5 menit) sudah diperbaiki di kode, belum diuji ulang
Kasus otomatis (run_cases.py)	19/20	TC-12 gagal di kode, lulus di percakapan
Uji unit (uji.py)	35/35	Termasuk 3 uji regresi dari temuan WorkBuddy
Uji serangan (uji_serangan.py)	52/52	File tersembunyi, makro, zip bomb, injeksi multibahasa, dampak nol bila detektor lolos
Masa pengembangan (19 Okt 2026)	F-01 GAGAL, F-02 GAGAL, F-03 lulus	F-01 kegagalan kritis: tanpa skill, Proyek Kenari bocor. Dilaporkan terbuka

Dokumen hasil uji lengkap dengan 12 screenshot ada di repo: submission/03_test_results.pdf dan folder evidence/.